



MUCHANGI & ASSOCIATES

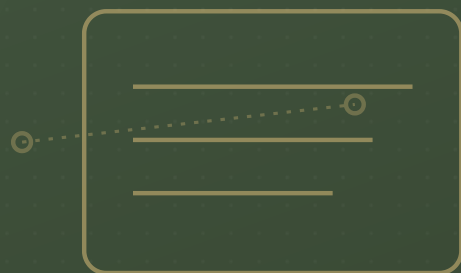
Advocates · Data Protection & Technology Law

REGISTRATION GUIDE SERIES

KPLR / RG / 003 / 2026

ODPC Registration for Technology Businesses

A sector guide to the registration threshold test, controller/processor roles and consent obligations for websites, e-commerce, SaaS and digital marketing businesses in Kenya.



TECHNOLOGY SECTOR · ODPC REGISTRATION · SAAS & E-COMMERCE · DATA CONTROLLER

AUTHOR

Patrick Muchangi

PUBLISHED

September 2026

SERIES

Kenya Privacy Law Review

ADVANCING EXCELLENCE IN PRIVACY, TECHNOLOGY & AI GOVERNANCE

ODPC Registration for Technology Businesses

A Sector Guide for Websites, E-Commerce, SaaS and Digital Marketing Businesses in Kenya

PUBLICATION DETAILS

REFERENCE

KPLR/RG/003/2026

EDITION

First Edition · Version 1.0

PUBLISHED

September 2026

AUTHOR

Patrick Muchangi, Advocate of the High Court of Kenya

PRACTICE AREAS

Data Protection & Privacy · Technology & Fintech · ODPC Disputes & Appeals

SECTOR

Technology

SPEAK TO THE FIRM

CALL

0722 878 607

WHATSAPP

0736 358 938

EMAIL

consult@dataprivacyadvocates.co.ke

WEBSITE

dataprivacyadvocates.co.ke

.....

This Guide is published as a free client-education resource by Muchangi & Associates Advocates. For advice on your own facility, contact the firm directly.

KENYA PRIVACY LAW REVIEW · REGISTRATION GUIDE SERIES

ODPC Registration for Technology Businesses

A sector guide for websites, e-commerce, SaaS and digital marketing businesses in Kenya.

IN THIS GUIDE

01. Introduction
02. The Legal and Regulatory Framework
03. The Two-Question Test: Must You Register at All?
04. Controller, Processor — or Both?
05. If You Must Register: Tiers and Fees
06. Information the ODPC Will Expect to See
07. Where Technology Businesses Get It Wrong
08. Step by Step: Registration and Correction Notices
09. Beyond Registration: Related Compliance Obligations
10. Case in Focus
11. Practical Compliance Checklist
12. Conclusion

AT A GLANCE

- Most general websites, e-commerce stores and SaaS platforms are **not** automatically mandatory registrants — unlike health and financial services, “technology” as such is not a named mandatory category.
- Specific technology business models are mandatory **regardless of size**: direct marketing, telecommunications or internet access providers, and online passenger-hailing or transport platforms.
- Exemption from registration is **not** exemption from needing a lawful basis to process personal data — an ODPC penalty against a Nairobi restaurant for an unconsented social media photo confirms this reaches any business with a website.
- SaaS and platform businesses frequently occupy a **dual role** — controller for their own subscriber and billing data, processor for data their business customers put into the platform.
- A start-up's data scale can trigger a Data Protection Officer requirement **well before** its turnover or headcount would trigger mandatory registration — the two thresholds are not the same test.

01 Introduction

Kenya's technology sector ranges from single-founder websites and e-commerce stores to venture-backed SaaS platforms and digital marketing agencies. Nearly all of them process personal data — account details, payment references, browsing and device data, marketing

contact lists — about users, customers and website visitors. The Data Protection Act, 2019 (“the Act”) requires an entity that determines the purpose and means of processing that data to register with the ODPC as a controller, unless it qualifies for the small-business exemption, and requires anyone processing data on another's behalf to register separately as a processor. Because “technology” is not itself a listed mandatory category, the registration analysis for this sector begins with a genuine threshold question rather than a foregone conclusion — and getting that question right, in either direction, is where this Guide starts.

02 The Legal and Regulatory Framework

The registration obligation arises from section 18 of the Act, given operational effect by the Data Protection (Registration of Data Controllers and Data Processors) Regulations, 2021 (Legal Notice No. 207 of 2021) (“the Registration Regulations”), which took effect on 14 July 2022. The Registration Regulations exempt data controllers and processors with an annual turnover below KES 5,000,000 and fewer than ten employees, provided the entity does not fall within a list of sectors the Regulations treat as inherently higher-risk regardless of size. Separately, the Data Protection (General) Regulations, 2021 govern the underlying obligations — lawful basis, consent, data subject rights, and the circumstances requiring a Data Protection Officer — that apply to registered and exempt entities alike.

03 The Two-Question Test: Must You Register at All?

For a technology business, the registration question is answered in two steps, and both matter.

- **First:** does your core activity fall within a mandatory category regardless of size? For this sector, the most relevant are businesses that are wholly or mainly in direct marketing, telecommunications network or internet access providers, and transport services firms, which the Regulations expressly extend to online passenger-hailing applications.
- **Second,** only if the answer to the first question is no: do you meet both exemption criteria — an annual turnover below KES 5,000,000 and fewer than ten employees? An entity that meets only one of the two criteria does not qualify for the exemption.

PRACTICAL INSIGHT

“Wholly or mainly” is a high bar. An e-commerce store that sends occasional promotional emails alongside its core retail activity is not, by virtue of that alone, a direct marketing business for this purpose — marketing is incidental to retail, not its main activity. A business whose core offering is bulk SMS campaigns, growth-marketing automation, or a client database sold for marketing use is a different case, and should assume mandatory registration applies regardless of size.

The scenarios below illustrate how the test typically resolves in practice — each should still be checked against the entity's actual facts rather than assumed from the category alone.

Scenario	Likely Position
A 2-person portfolio/informational website with a contact form, turnover under KES 5M	Likely exempt — not a named mandatory category and below both thresholds
A bulk SMS or email marketing platform with 3 staff	Mandatory regardless of size — “wholly or mainly in direct marketing”
A ride-hailing or courier-dispatch app, any size	Mandatory regardless of size — “transport services firms including online passenger hailing applications”
A general-purpose SaaS tool (e.g. project management, invoicing) with 8 staff, turnover KES 4M	Likely exempt for now — reassess as headcount/turnover grow
An e-commerce store running occasional promotional email/SMS as one of several activities	Threshold test applies — “wholly or mainly” direct marketing is a high bar; ordinary retail marketing does not, by itself, meet it
An internet service provider or web hosting company, any size	Mandatory regardless of size — “internet access provider” / “telecommunications network or service provider”

04 Controller, Processor — or Both?

A website, e-commerce store or SaaS platform is ordinarily a data controller in respect of its own users, customers and website visitors. Many technology businesses are, in addition, a data processor in respect of data their own business customers put into the

platform — a CRM or helpdesk tool processes its client's end-customers' data on the client's instructions, for example, making the SaaS provider a processor for that data while remaining a controller for its own subscriber and billing records. Each role should be assessed and, where both apply and registration is otherwise required, declared separately. A platform should also identify its own processors — cloud hosting providers, payment gateways, email or SMS delivery services, analytics tools — and should not assume that a vendor's own compliance (an AWS or Google Workspace certification, for instance) satisfies the platform's own registration or disclosure obligations.

05 If You Must Register: Tiers and Fees

Where registration is required — whether because a mandatory category applies or because the entity exceeds the exemption thresholds — private-sector data controllers and processors are classified into three tiers based on annual turnover and employee numbers.

Tier	Size Criteria	Registration Fee (once-off)
Micro & Small	1–50 employees; turnover up to KES 5,000,000	KES 4,000
Medium	51–99 employees; turnover KES 5,000,001–50,000,000	KES 16,000
Large	More than 99 employees; turnover above KES 50,000,000	KES 40,000
Public / Charitable or Faith-Based Entities	Regardless of turnover or staff numbers	KES 4,000

A certificate of registration is valid for 24 months from the date of issue and must be renewed at least 30 days before expiry; renewal fees are lower than initial registration fees (currently KES 2,000 for Micro & Small, KES 9,000 for Medium, and KES 25,000 for Large).

06 Information the ODPC Will Expect to See

Where registration applies, a complete application requires a clear and internally consistent description of the business's data processing activities, beyond basic

establishment details such as a certificate of incorporation and a KRA PIN:

- **Categories of data subjects processed** — registered users, customers, website visitors, and, for a SaaS platform, its business customers' own end-users where the platform processes that data.
- **Categories of personal data processed** — account and identification data, payment references (noting that card data itself is typically held by a payment gateway, not the merchant), device and analytics data, and marketing contact lists.
- **The specific purposes** for which data is processed — service delivery, billing, product analytics, and marketing should be distinguished rather than bundled into a single generic purpose.
- **Recipients** to whom data is disclosed — payment gateways, cloud hosting providers, email/SMS delivery services, and analytics or advertising vendors.
- **Any transfer of data outside Kenya** — for a technology business this is close to the default position, since most cloud hosting, SaaS tooling and analytics infrastructure sits outside the country.
- **The safeguards in place** — access controls, encryption, and a documented basis for any cookies, tracking scripts or analytics tools deployed on the website or app.

07 Where Technology Businesses Get It Wrong

The following gaps are the ones we most commonly see — in registration applications where registration is required, and in general compliance posture where it is not.

COMMON MISTAKE — MISJUDGING THE EXEMPTION IN EITHER DIRECTION

The two failure modes are symmetrical and equally common: registering (and paying a fee) while genuinely exempt, and assuming exemption as a “small start-up” while operating a business — bulk marketing, ride-hailing, internet access — that is mandatory regardless of size. Both stem from treating the sector, rather than the specific activity and the actual thresholds, as the test.

COMMON MISTAKE — UNDOCUMENTED CONSENT FOR WEBSITE AND SOCIAL MEDIA CONTENT

Posting customer photographs, testimonials or case studies on a website or social media page without a documented consent record. This applies whether or not the business is required to register, and is the exact conduct that produced a KES 1,850,000 ODPC penalty against a Nairobi restaurant in 2023 (see Case in Focus, section 10).

COMMON MISTAKE — ASSUMING VENDOR COMPLIANCE COVERS THE BUSINESS'S OWN OBLIGATION

Treating a cloud host, email platform or analytics vendor's own certifications as a substitute for the business's own registration, disclosure and consent obligations. The vendor's compliance addresses the vendor's role; it does not discharge the business's role as controller.

COMMON MISTAKE — NO DOCUMENTED BASIS FOR COOKIES AND TRACKING

Deploying analytics, advertising or tracking scripts that collect device or behavioural data without a documented lawful basis or a clear notice to the website visitor. Data collected this way is personal data like any other where it can identify or relate to an individual, and is treated as such under the Act.

COMMON MISTAKE — MARKETING LISTS BUILT FROM PURCHASED OR SCRAPED CONTACTS

The Act requires personal data to be collected directly from the data subject in most circumstances. A marketing list assembled from purchased, scraped, or third-party-sourced contacts — rather than opt-in collection — raises the same lawful-basis problem the ODPC has penalised in other sectors for using third-party-sourced contact data without consent.

COMMON MISTAKE — UNDISCLOSED CROSS-BORDER HOSTING

Where registration applies, failing to disclose that user data is processed on cloud infrastructure located outside Kenya. This overlaps with, and should be read alongside, the firm's Practice Note on Cross-Border Data Transfers (KPLR/PN/003/2026).

08 Step by Step: Registration and Responding to a Correction Notice

- Work through the two-question test in section 3 first, and document the conclusion — this is worth keeping on file even where the answer is that registration is not required.
- Where registration is required, prepare the data inventory set out in section 6 before opening the online application.
- Submit the application through the ODPC's online portal and pay the applicable tier fee.
- Where the Data Commissioner is satisfied, a certificate of registration is issued within 14 days of a complete submission.
- Where the Data Commissioner is not satisfied, a written refusal notice is issued within 21 days, setting out the specific reasons for rejection.
- A rejected applicant may cure the identified deficiencies and make a fresh application — this attracts a new registration fee.
- Once issued, the certificate is valid for 24 months and must be renewed at least 30 days before expiry.
- Reassess the exemption position as the business grows — crossing either threshold, or pivoting into a mandatory activity such as bulk marketing, removes the exemption going forward.

09 Beyond Registration: Related Compliance Obligations

Registration status and underlying compliance obligations are separate questions, and a technology business should not assume the two move together.

- **Appointment of a Data Protection Officer**, required where an organisation processes personal data at scale or conducts systematic monitoring of data subjects — a threshold a fast-growing platform can cross on data volume well before it crosses the turnover or headcount figures relevant to registration.
- **A Data Protection Impact Assessment** before deploying high-risk processing such as behavioural profiling, algorithmic personalisation, or biometric authentication.
- **A clear privacy notice** covering account data, payment references, and any cookies or tracking technology used on the site or app, in language a user can reasonably be

expected to understand.

- **Written data processing agreements** with cloud hosts, payment gateways, and any analytics or marketing vendor that processes user data on the business's behalf.
- **A breach-response procedure** calibrated to the Act's notification timelines — notification to the ODPC without undue delay and within the statutory window, with prompt processor-to-controller notification where a vendor is involved.

10 Case in Focus

ODPC PENALTY NOTICES, SEPTEMBER 2023 — CONSENT FOR IMAGES ON DIGITAL PLATFORMS

In September 2023, the ODPC issued penalty notices to three data controllers, with fines ranging from KES 1,850,000 to KES 4,550,000. Two of the three concerned consent for images posted on a digital platform.

A restaurant in Nairobi was fined KES 1,850,000 for posting a customer's photograph on the business's social media page without the customer's consent. The ODPC's guidance on consent requires it to be express, unequivocal, freely given and specific — and the burden of proving consent was obtained rests with the business, not the customer. A separate penalty of KES 4,550,000, the highest of the three, was issued to a school for posting images of minors without parental consent, reflecting the Act's heightened requirement for consent from a parent or guardian before processing a child's personal data, including their image.

A third penalty of KES 2,975,000 was issued to a digital credit provider in the same period, for using contact information obtained from third parties without consent for debt-recovery communications.

Relevance to this sector. The restaurant penalty is not a health-sector or financial-services fact pattern — it is a small, general business whose only relevant “technology” activity was maintaining a social media page. It confirms that the consent obligation applies to any business with a digital presence, irrespective of size, sector, or registration status, and that a business proposing to post customer photographs, testimonials or case studies on its website or social media should treat documented consent as a precondition, not a formality.

11 Practical Compliance Checklist

STEP ZERO — DETERMINE WHETHER YOU MUST REGISTER

- ☒ Confirmed whether the business's core activity is wholly or mainly direct marketing, telecommunications/internet access, or transport/passenger-hailing.
- ☒ If none of the above, checked actual turnover and employee numbers against both exemption criteria, and documented the conclusion.
- ☒ Set a reminder to reassess the exemption position at the next significant growth milestone.

BEFORE YOU APPLY (WHERE REGISTRATION IS REQUIRED)

- ☒ Prepared a complete data inventory: users/customers, website visitors, and any end-user data processed on behalf of business customers, stated separately.
- ☒ Confirmed controller/processor scope, including any dual role as both.
- ☒ Documented specific technical and organisational safeguards, including the basis for any cookies or tracking tools in use.
- ☒ Identified all recipients, including payment gateways, cloud hosts, and marketing/analytics vendors.
- ☒ Identified any offshore hosting arrangement and prepared to disclose it.

ONGOING — REGARDLESS OF REGISTRATION STATUS

- ☒ Obtained and documented consent before posting any customer photograph, testimonial or case study on the website or social media.
- ☒ Built marketing lists from opt-in, directly collected contacts rather than purchased or scraped sources.
- ☒ Assessed whether data scale triggers a Data Protection Officer appointment, independently of the registration threshold.
- ☒ Put in place data processing agreements with cloud, payment and marketing vendors.
- ☒ Established a breach-response procedure with statutory ODPC notification timelines built in.

12 Conclusion

For a Kenyan technology business, the registration question is not a foregone conclusion in either direction, and that is precisely what makes it worth answering carefully rather than assuming. A business that gets the two-question test right avoids both unnecessary fees and an unwelcome correction notice — and a business that treats the underlying consent and lawful-basis obligations as applying regardless of registration status will generally find that the registration analysis, when it is required, is the easy part. The Nairobi restaurant case is a useful corrective to any assumption that these obligations are only a concern for large or sector-specific businesses: a social media page was enough.

KEY TAKEAWAYS

- Most general websites, e-commerce stores and SaaS platforms are **not** automatically mandatory registrants — unlike health and financial services, “technology” as such is not a named mandatory category.
- Specific technology business models are mandatory **regardless of size**: direct marketing, telecommunications or internet access providers, and online passenger-hailing or transport platforms.
- Exemption from registration is **not** exemption from needing a lawful basis to process personal data — an ODPC penalty against a Nairobi restaurant for an unconsented social media photo confirms this reaches any business with a website.
- SaaS and platform businesses frequently occupy a **dual role** — controller for their own subscriber and billing data, processor for data their business customers put into the platform.
- A start-up's data scale can trigger a Data Protection Officer requirement **well before** its turnover or headcount would trigger mandatory registration — the two thresholds are not the same test.

AUTHOR'S PERSPECTIVE

Technology clients tend to ask us the registration question as though it has one answer for the whole sector, and it doesn't — a ride-hailing app and a portfolio website sit at opposite ends of the same Regulations. The more useful question, and the one we push clients toward, is not “do tech companies need to register” but “what, specifically, does our business do, and does that specific activity meet a specific test.” Businesses that answer that question properly once tend not to need to revisit it until they've genuinely outgrown the answer.

How We Can Help. We advise websites, e-commerce stores, SaaS platforms and digital marketing businesses on the registration exemption test, dual controller/processor registrations, and the wider consent and cookie-notice obligations that apply regardless of registration status. If any part of this Guide describes your business, we would be glad to talk it through with you.

CALL THE FIRM**0722 878 607****WHATSAPP****0736 358 938****ONLINE****dataprivacyadvocates.co.ke****MP****MUCHANGI PATRICK**

Advocate of the High Court of Kenya · Founder, Muchangi Patrick & Associates Advocates. Patrick Muchangi is a boutique-practice advocate specialising in data protection, privacy, AI governance and technology law. He is a Certified Professional Mediator, holds an LL.B from the University of Nairobi and a Post-Graduate Diploma from the Kenya School of Law, and edits the Kenya Privacy Law Review.

RECOMMENDED CITATION

Muchangi & Associates Advocates, “ODPC Registration for Technology Businesses: A Sector Guide for Websites, E-Commerce, SaaS and Digital Marketing Businesses in Kenya”, Registration Guide No. 003, KPLR/RG/003/2026 (September 2026).

This Guide is prepared for general informational and educational purposes as part of the Kenya Privacy Law Review series on data protection, privacy, and AI governance. It does not constitute legal advice and should not be relied upon as a substitute for advice from qualified Kenyan counsel on the specific facts of any business's operations. Reading this publication does not create an advocate-client relationship with Muchangi Patrick & Associates Advocates.